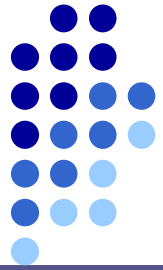
CYBERSECURITY FRAMEWORK

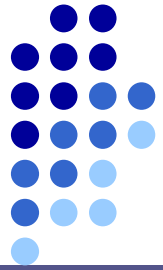
กรอบงานความมั่นคงไซเบอร์

Topic



- Cybersecurity Framework
- Well-known Frameworks

Cybersecurity Framework

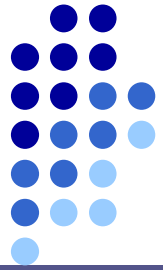


- A cybersecurity framework is a structured set of guidelines, best practices, and standards designed to help organizations manage and reduce their cybersecurity risks.

Type of Cybersecurity Framework

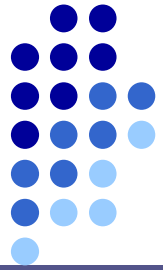
- Risk frameworks
- Program frameworks
- Control frameworks

Risk Frameworks



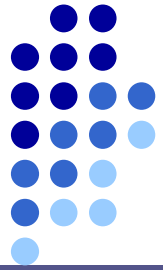
- Cybersecurity risk frameworks are essential tools for organizations to manage security risks effectively.
- They offer a well-organized approach to risk management, enabling organizations to prevent possible threats and develop practical strategies for mitigating cyber attacks.
- Risk frameworks are checklists for enhancing security.
- Examples of widely used risk frameworks include NIST 800-30 and ISO 27005.

Program Frameworks



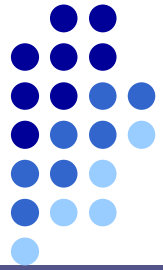
- Program frameworks are guidelines that help improve security efforts.
- They are roadmaps for building and maintaining a robust cybersecurity program and help to ensure that all necessary activities, such as risk assessment, training, monitoring, and incident response, are carried out effectively.
- The NIST Cybersecurity Framework and ISO/IEC 27001 are two examples of widely used program frameworks.

Control Frameworks



- Structured policies and procedures that organizations can follow to mitigate cyber threats.
- Control frameworks offer a fundamental approach to assessing the existing technical conditions and improving the security posture.
- Examples of control frameworks include NIST 800-53, CIS Critical Security Controls, and PCI DSS.
- By implementing these frameworks, organizations can thoroughly evaluate their security protocols and identify gaps that require attention.

Well-known Frameworks



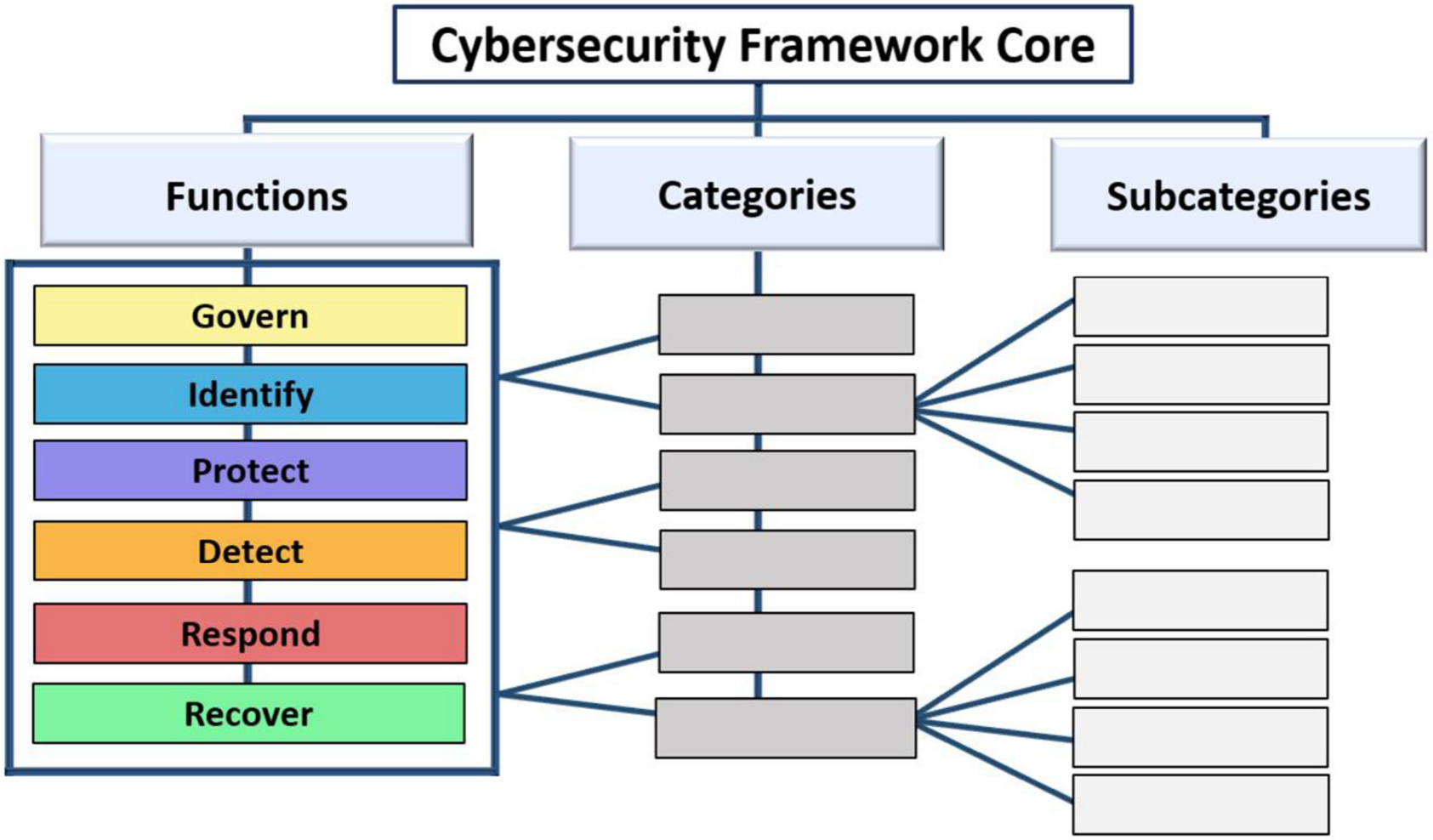
- NIST
- ISO 27001 and ISO 27002
- CIS Controls
- COBIT
- PCI-DSS
- HITRUST / HIPAA

NIST

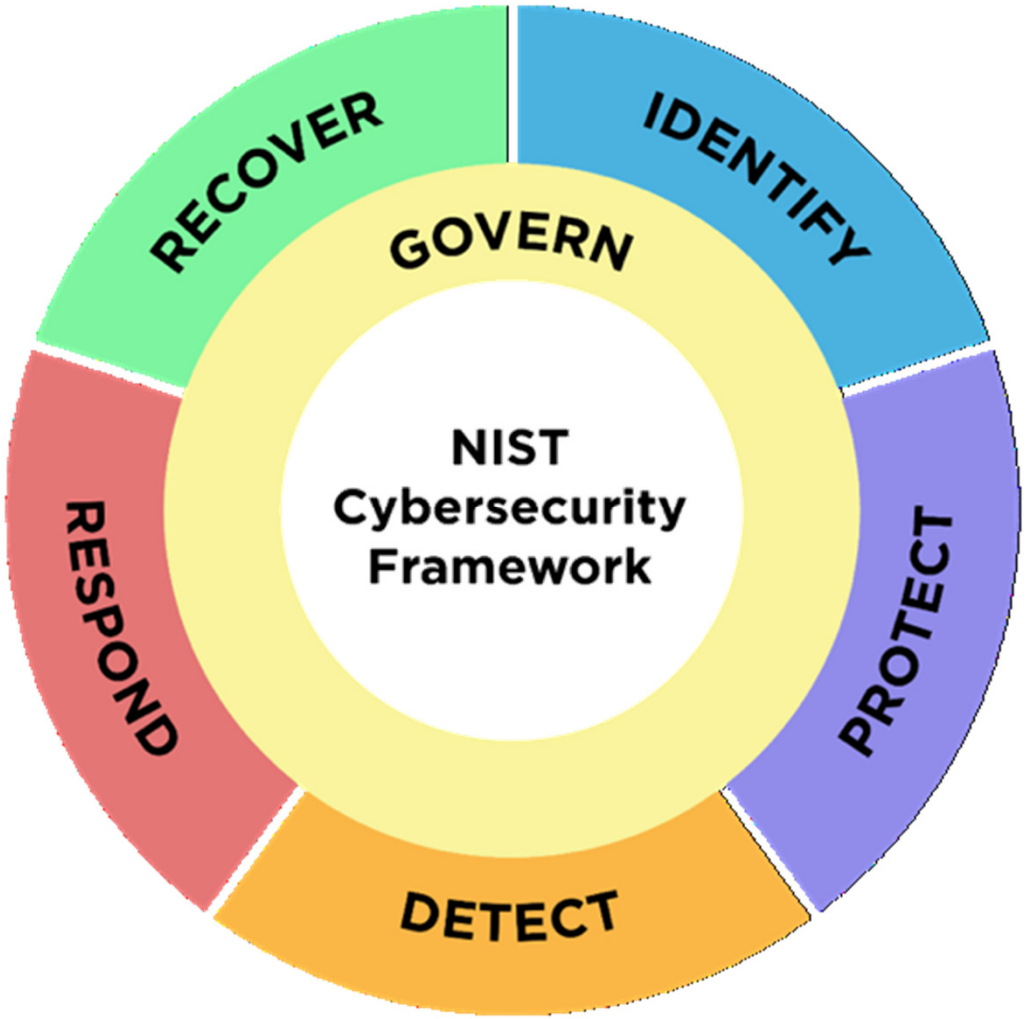
- The NIST Cybersecurity Framework (NIST CSF) provides comprehensive guidance and best practices that private sector organizations can follow to improve information security and cybersecurity risk management.



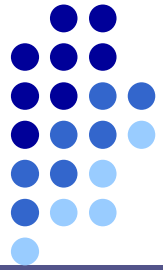
NIST CSF


Cybersecurity Framework Core
Functions
Categories
Subcategories
Govern
Identify
Protect
Detect
Respond
Recover

NIST CSF Functions

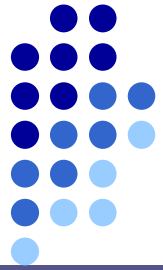


NIST CSF Functions



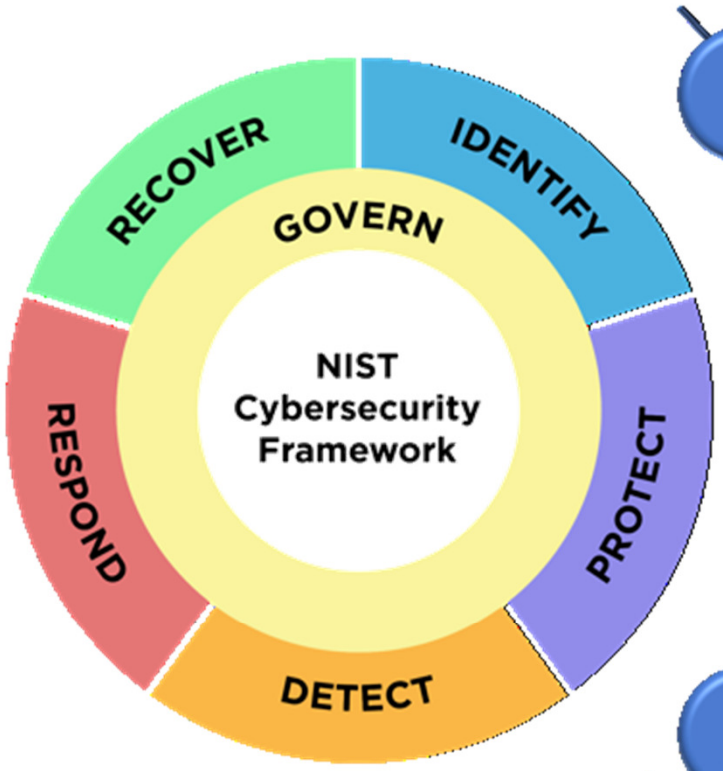
- Govern : *The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored.*
- Identify : *The organization's current cybersecurity risks are understood.*
- Protect : *Safeguards to manage the organization's cybersecurity risks are used.*
- Detect : *Possible cybersecurity attacks and compromises are found and analyzed.*

NIST CSF Functions



- Respond : *Actions regarding a detected cybersecurity incident are taken.*
- Recover : *Assets and operations affected by a cybersecurity incident are restored.*

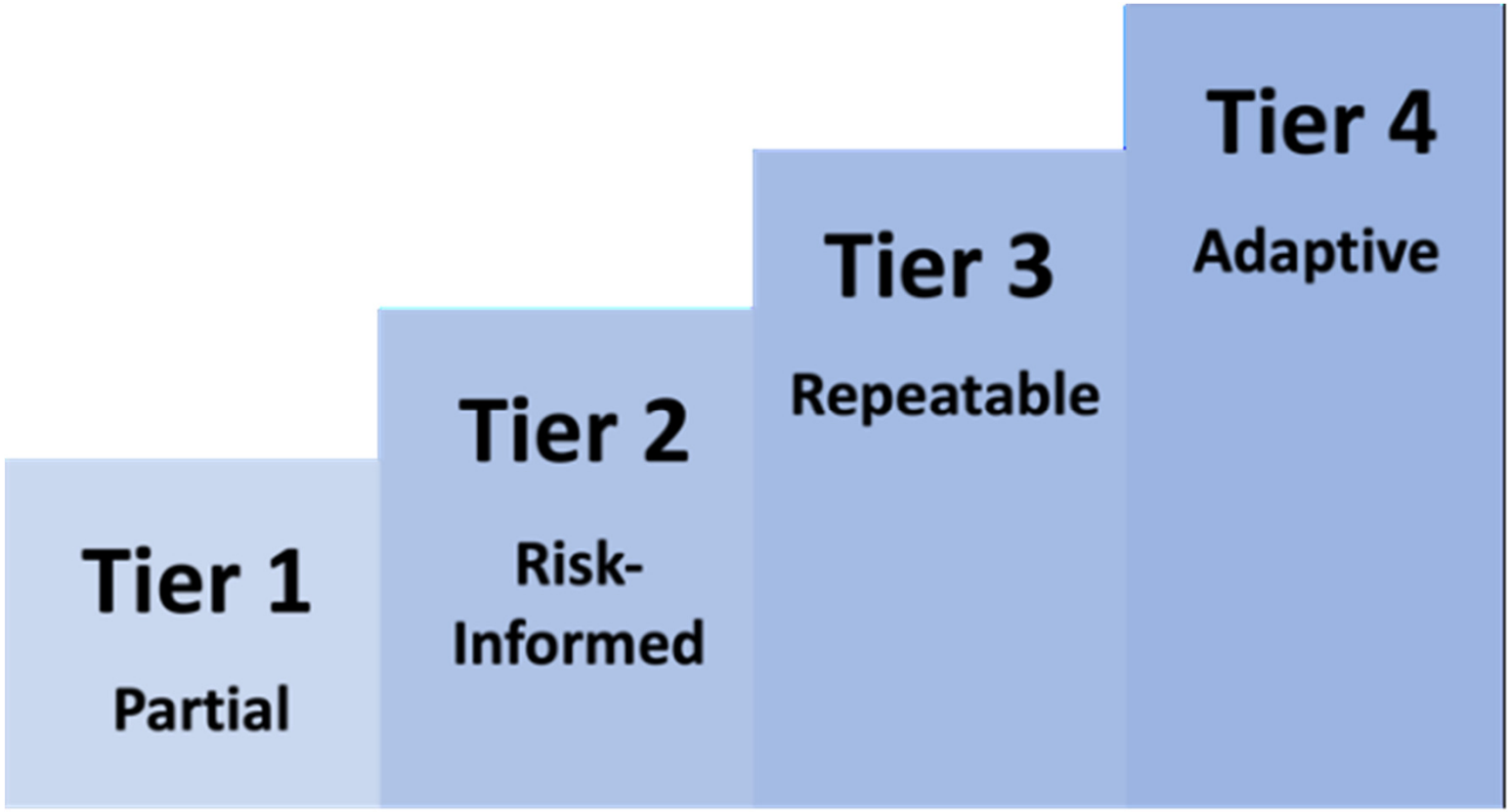
Create and Using CSF



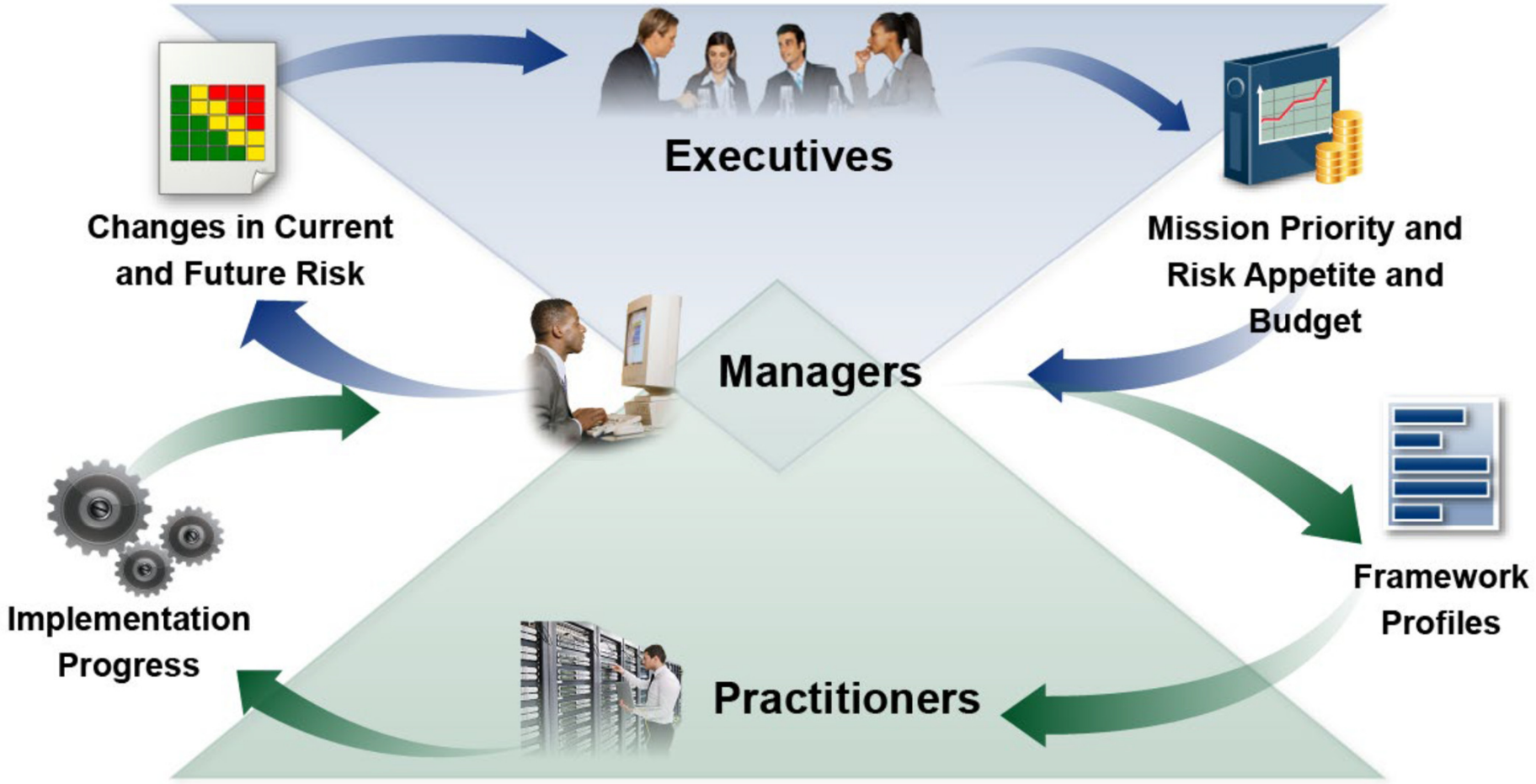
1. Scope the Organizational Profile
2. Gather needed information
3. Create the Organizational Profile
4. Analyze gaps and create an action plan
5. Implement action plan and update Profile

Repeat...

NIST CSF Tiers



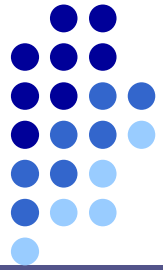
Risk Management Communication



NIST CSF 2.0 Category

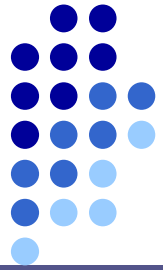
Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Roles, Responsibilities, and Authorities	GV.RR
	Policy	GV.PO
	Oversight	GV.OV
	Cybersecurity Supply Chain Risk Management	GV.SC
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

ISO 27001 and ISO 27002



- The two of the most common standards for information security management.
- Provide a comprehensive framework for organizations looking to protect their data through robust policies and best practices.
- Initially developed by the International Organization for Standardization (ISO)
- Lay out principles and practices that ensure organizations take appropriate measures to protect their data.

ISO 27001 and ISO 27002



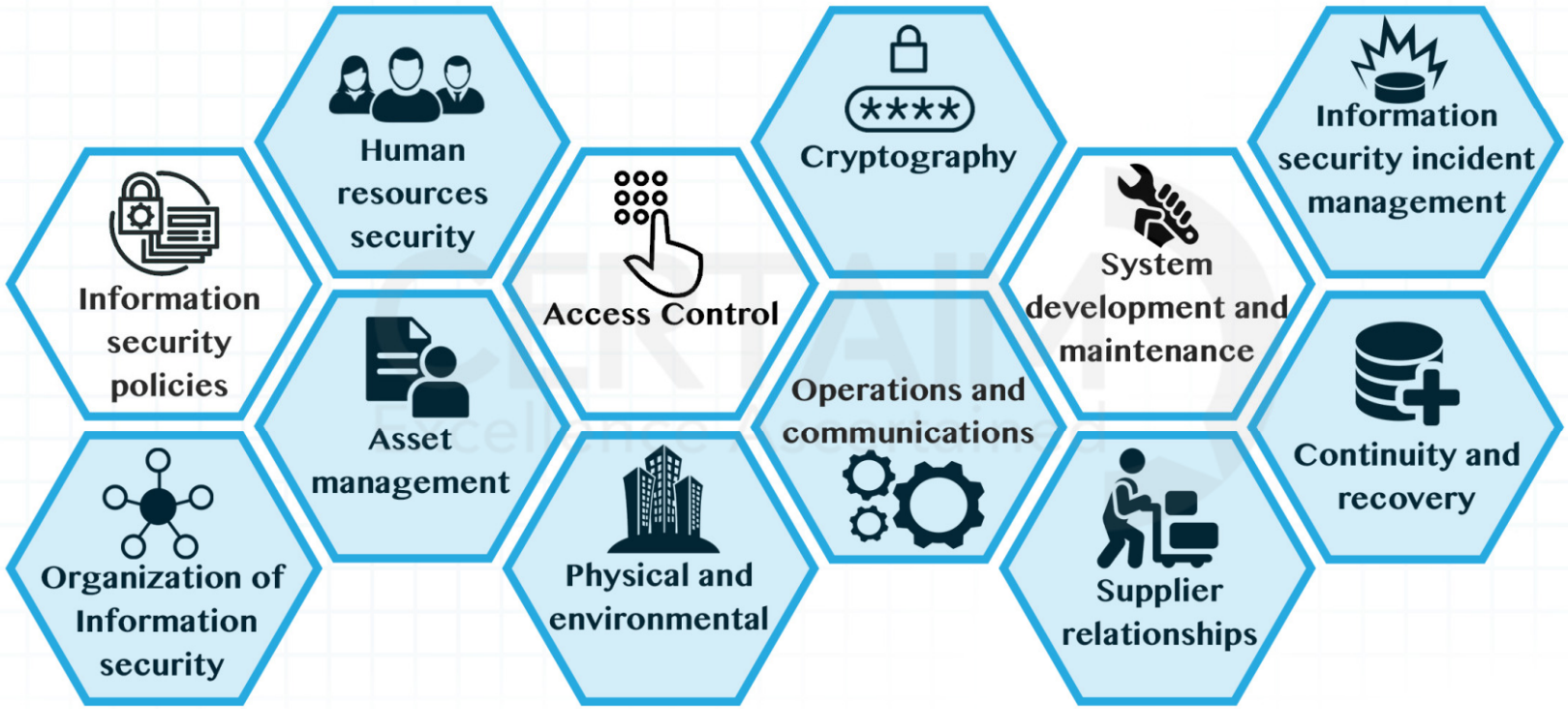
- ISO 27001
  - systematic approach to risk assessment, control selection, and implementation
  - includes requirements for establishing an information security management system (ISMS)
- ISO 27002
  - code of practice that outlines more specific and detailed cybersecurity controls

ISO 27001 Key Requirements and Features



ISO 27001 Controls

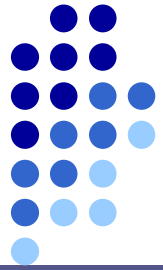
ISO 27001 certification comprises of 114 controls in 14 groups and 35 control objectives ensuring all the information covering people process supplier vendors and technology are safe and secure



Certification Process

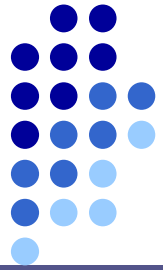


CIS Controls



- The Center for Internet Security (CIS) Control Framework
- Best practices for organizations seeking to protect their networks from cyber threats
- 20 controls, covering many areas of cybersecurity, including access control, asset management, and incident response.

CIS Controls Categories



- Basic
  - focus on the essential cybersecurity measures that all organizations should implement, such as regular patching and antivirus protection
- Foundational
  - more advanced measures that should be taken in addition to fundamental cybersecurity protocols
- Organizational
  - additional protections specific to the needs of an organization's environment

Controls Categories

CIS Controls®

V7.1

Basic

1. Inventory and Control of Hardware Assets
2. Inventory and Control of Software Assets
3. Continuous Vulnerability Management
4. Controlled Use of Administrative Privileges
5. Secure Configuration for Hardware and Software on Mobile Devices, Laptops, Workstations and Servers
6. Maintenance, Monitoring and Analysis of Audit Logs

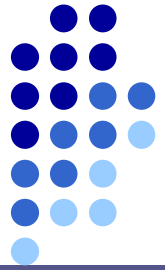
Foundational

7. Email and Web Browser Protections
8. Malware Defenses
9. Limitation and Control of Network Ports, Protocols and Services
10. Data Recovery Capabilities
11. Secure Configuration for Network Devices, such as Firewalls, Routers and Switches
12. Boundary Defense
13. Data Protection
14. Controlled Access Based on the Need to Know
15. Wireless Access Control
16. Account Monitoring and Control

Organizational

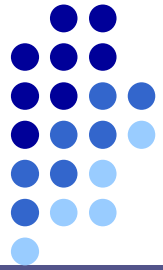
17. Implement a Security Awareness and Training Program
18. Application Software Security
19. Incident Response and Management
20. Penetration Tests and Red Team Exercises

COBIT



- Control Objectives for Information and related Technology (COBIT)
- Developed by the Information Systems Audit and Control Association (ISACA)
- Comprehensive framework designed to help organizations manage their IT resources more effectively
- Best practices for governance, risk management, and cybersecurity

COBIT Categories

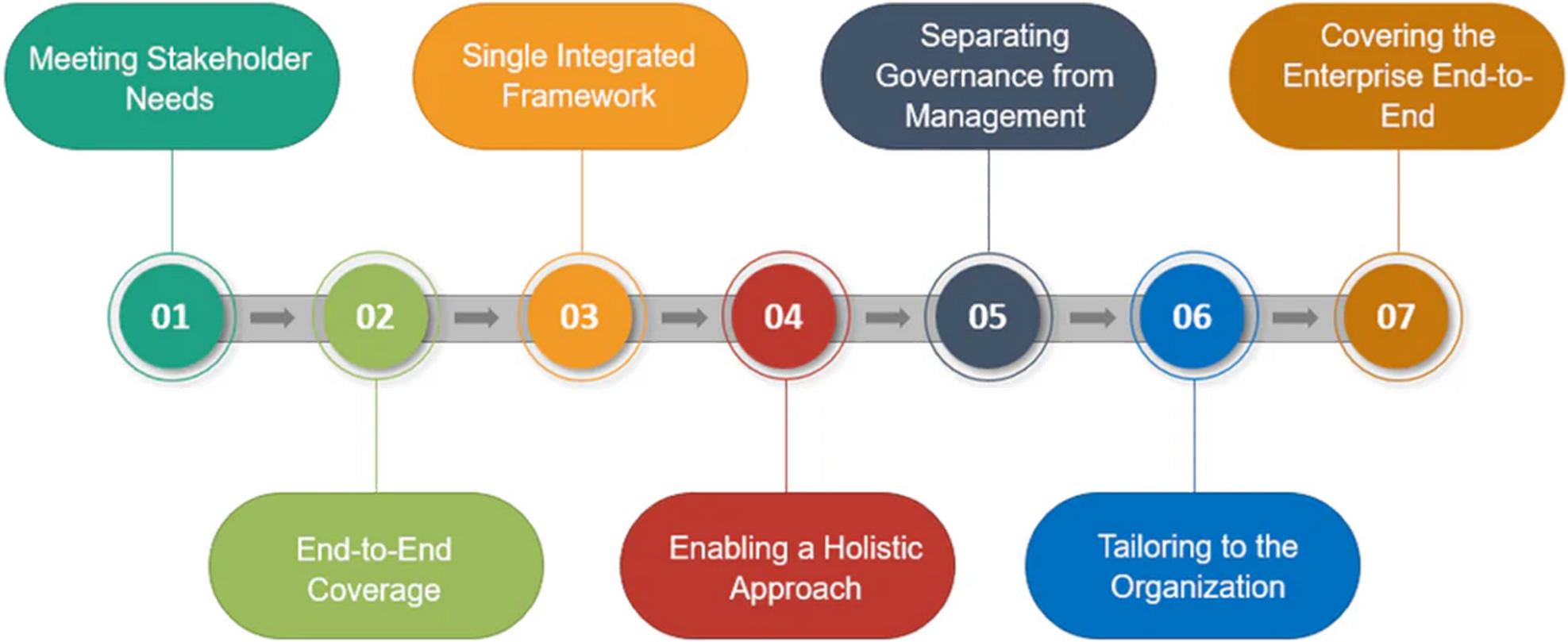


- Plan & Organize
- Acquire & Implement
- Deliver & Support
- Monitor & Evaluate
- Manage & Assess

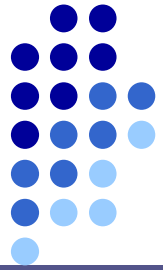
COBIT 5 Key Principles



COBIT 5 Keys Concepts



PCI-DSS

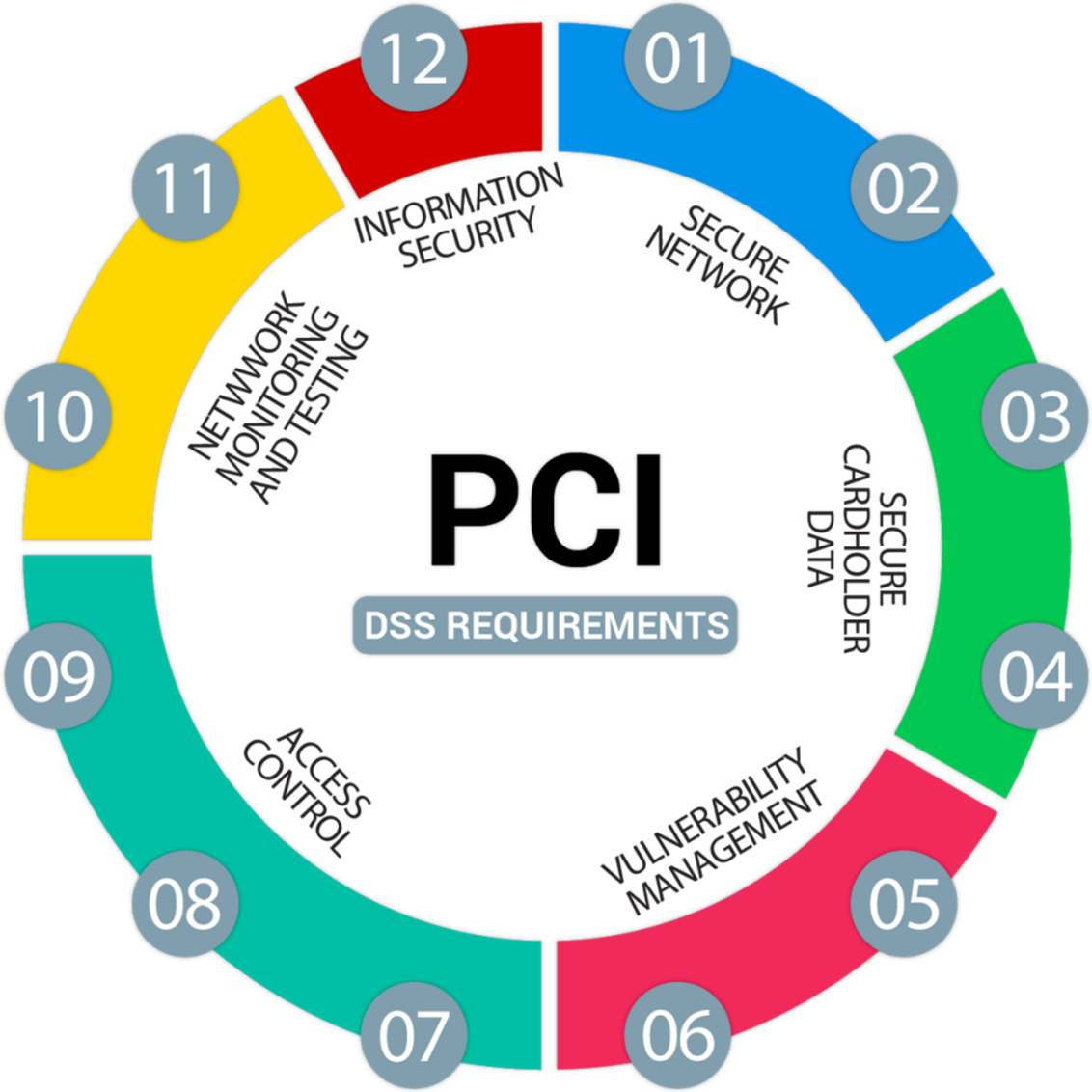


- Payment Card Industry Data Security Standard
- Protect customers' payment card data
- Comprehensive set of requirements designed to help organizations secure their systems and prevent unauthorized access to customer information
- 12 requirements cover access control, network security, and data storage specific to the payment processing industry

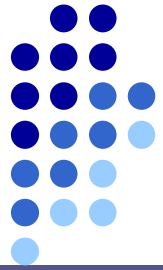
PCI-DSS Requirements

1.  Firewall configuration has to be installed and maintained
2.  Original system passwords should be used (not vendor-supplied)
3.  Stored cardholder data has to be protected
4.  Encrypted transmission of cardholder data
5.  Anti-virus software should be regularly used and updated
6.  Secure applications and systems have to be developed and maintained
7.  Access to cardholder data should be restricted to business need-to-know
8.  Each person with computer access should have a unique ID
9.  Physical access to cardholder data should be restricted
10.  All access to network resources and cardholder data has to be tracked and monitored
11.  Security systems and processes should be regularly tested
12.  A policy that addresses information security for employees and contractors should be maintained

Requirement Categories



HITRUST



- The Health Information Trust Alliance (HITRUST)
- Designed for the healthcare industry
- Best practices for protecting the security of patient data, covering areas such as access control, identity and access management, encryption, audit logging, and incident response
- Includes detailed cybersecurity governance, risk management, and compliance requirements

HITRUST Facts

The HITRUST CSF Certification is different from other certifications

Achievement of the **HITRUST CSF® Certification** demonstrates that an organization is adhering to the highest information security standards. The HITRUST Common Security Framework offers one of the most comprehensive certifications available.

HITRUST CSF Certified

The HITRUST CSF Certification mapped to other critical security frameworks

HITRUST CSF is the information protection framework for the health care industry for addressing rigorous **HIPAA standards**, as well providing a certifiable framework that includes, harmonizes and cross-references existing, globally recognized standards, regulations and business requirements—including **HIPAA, HITECH, NIST, ISO, PCI, FTC, COBIT, and GDPR.**

The many requirements the Common Security Framework has

The Common Security Framework consists of **270 requirements** spread across **19 domains** ranging from acces controls and business continuity to risk management and data protection and privacy.



Why HITRUST CSF is considered an example of "assess once, report many" approach to certification?

Some security frameworks allow businesses to address **multiple security** requirements using a **single certification.**



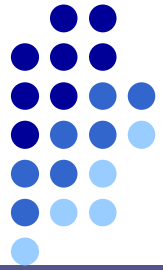
HITRUST Approach



Certified Process

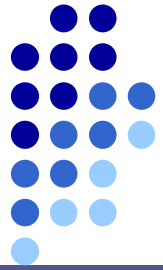


HIPAA



- Health Insurance Portability and Accountability Act
- The HIPAA Security Rule specifically focuses on the safeguarding of electronic protected health information (EPHI)
- Protecting the confidentiality, integrity, and availability of EPHI
- Covered entity creates, receives, maintains, or transmits must be protected against reasonably anticipated threats, hazards, and impermissible uses and/or disclosures.

HIPAA Key Components



- HIPAA Privacy Rule: *Details how protected health information (PHI) must be safeguarded.*
- HIPAA Security Rule: *Focuses on the security of electronic health information.*
- Administrative Simplification provisions: *Require national standards for electronic health care transactions, code sets, unique health identifiers, and security.*
- Patient consent and knowledge: *HIPAA ensures that sensitive patient health information is not disclosed without consent or knowledge.*

HIPAA Rules



1. Privacy Rule

The HIPAA Privacy Rule establishes standards to protect individuals' electronic medical records and personal health information and how it can be used and not disclosed.



2. Security Rule

The HIPAA Security Rule establishes standards to protect individuals' electronic personal health information with right safeguards must be in place to ensure appropriate protection (see below).



3. Transaction Rule

The HIPAA Transaction Rule address the safety, accuracy and security of medical records in transactions and PHI

4. Identifiers Rule

The HIPAA Identifiers Rule ensures unique identifiers.



5. Enforcement Rule

The HIPAA Rle addresses the authority's power to enforce penalties for violations and set the breach reporting requirements.

Compliance Checklist



TECHNICAL PROTECTIONS

- ENCRYPT & AUTHENTICATE EPHI
- CONTROL/LOG ACCESS & CHANGES TO EPHI
- AUTO-LOGOFF



PHYSICAL PROTECTIONS

- CONTROL/MONITOR PHYSICAL ACCESS
- MANAGE WORKSTATIONS
- PROTECT & TRACK EPHI DEVICES



ADMINISTRATIVE PROTECTIONS

- ASSESS & MANAGE RISK
- TRAIN STAFF
- BUILD/TEST CONTINGENCIES
- BLOCK UNAUTHORIZED ACCESS
- SIGN BAAS
- DOCUMENT SECURITY INCIDENCES



HIPAA PRIVACY RULE TO-DO

- RESPOND TO PATIENT ACCESS REQUESTS
- INFORM PATIENTS WITH NPPS
- TRAIN STAFF
- MAINTAIN EPHI INTEGRITY
- GET PERMISSION TO USE EPHI
- UPDATE FORMS/COPY



HIPAA BREACH NOTIFICATION RULE TO-DO

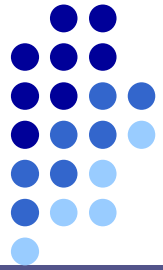
- PROMPTLY NOTIFY PATIENTS
- HHS & POTENTIALLY THE MEDIA
- ENSURE YOUR NOTIFICATION CONTAINS THE 4 REQUIRED ELEMENTS



HIPAA OMNIBUS RULE TO-DO

- REFRESH YOUR BAA
- SEND NEW COPIES
- UPDATE PRIVACY POLICIES
- MODERNIZE NPPS
- TRAIN STAFF

References



- https://clarusway.com/cybersecurity-frameworks/
- https://www.ibm.com/topics/nist
- https://www.connectwise.com/blog/cybersecurity/11-best-cybersecurity-frameworks
- https://www.nist.gov/cyberframework/nists-journey-csf-20

Questions ?